

Security+ 1.4 · Encryption Technologies

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 1.4** —
Encryption Technologies (6:53) · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

Executive Lesson Summary: Hardware-based encryption technologies include TPM (a chip on the motherboard that measures boot integrity and stores keys, forming the basis of BitLocker), HSM (a dedicated appliance for managing high-value cryptographic keys, used by banks and governments), Secure Enclave (an isolated CPU area in Apple devices for biometric and payment data), and SED (self-encrypting drives that automatically encrypt all data).

High-Yield Core Concepts Tested on Exam

- TPM (Trusted Platform Module) is a physical chip that measures boot process and stores keys
- HSM (Hardware Security Module) is a dedicated appliance for high-value key operations
- Secure Enclave is a segregated processor (Apple) for biometrics and payments
- SED (Self-Encrypting Drive) encrypts data automatically at the drive level
- TPM is often used for full disk encryption like BitLocker

Exam Tips & Classic Scenarios

- 'chip on the motherboard that measures boot process' = TPM
- 'dedicated appliance for cryptographic key operations' = HSM
- Secure Enclave is specific to Apple devices; HSM is for enterprise key management

Typical Exam Scenario: A company issues encryption keys for its database and requires physical hardware protection for those keys. This is best achieved with an HSM.

Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 1.4 — Encryption Technologies)

Why is this advanced coverage required for SY0-701? Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **TPM:** Trusted Platform Module: Hardware cryptoprocessor embedded on host motherboards storing cryptographic keys (BitLocker), validating boot integrity, and preventing physical tampering.
- **HSM:** Hardware Security Module: Dedicated tamper-resistant physical appliance generating, protecting, and managing high-capacity cryptographic keys.

Classic CompTIA Traps & Question Framing:

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

Practice Questions with In-Depth Solutions (10 Questions)

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

1. MFA combines factors from different categories. Which trio represents the 3 categories?

- A)** Password, PIN, and secret answer
- B)** Something you know, something you have, something you are
- C)** 3 different passwords
- D)** Username, password, and email

2. In a PKI infrastructure, which component is responsible for validating and revoking digital certificates?

- A) RA (Registration Authority)**
- B) CA (Certificate Authority)**
- C) CRL (Certificate Revocation List)**
- D) OCSP (Online Certificate Status Protocol)**

3. Service that manages encryption keys in the cloud (create, rotate, control access):

- A) KMS (Key Management Service)**
- B) IAM**
- C) CDN**
- D) VPC**

4. Corporate scenario (Encryption Technologies): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 1.4), an analyst evaluates the following technical requirement: 'TPM = Trusted Platform Module — physical chip; measures boot + stores key'. What is the best recommendation or applicable control classification?

- A) Implement the corresponding solution: TPM = Trusted Platform Module — physical chip; measures boot + stores key...**
- B) Temporarily disable audit logs to accelerate system throughput**
- C) Replace preventive technical controls with informal terms of adherence**
- D) Allow shared access among administrators using generic credentials**

5. Corporate scenario (Encryption Technologies): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 1.4), an analyst evaluates the following technical requirement: 'HSM = Hardware Security Module — dedicated for high-value keys'. What is the best recommendation or applicable control classification?

- A) Temporarily disable audit logs to accelerate system throughput**
- B) Implement the corresponding solution: HSM = Hardware Security Module — dedicated for high-value keys...**
- C) Replace preventive technical controls with informal terms of adherence**
- D) Allow shared access among administrators using generic credentials**

6. Corporate scenario (Encryption Technologies): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 1.4), an analyst evaluates the following technical requirement: 'Secure Enclave: segregated processor (Apple) for biometrics/payment'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: Secure Enclave: segregated processor (Apple) for biometrics/payment.
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

7. Corporate scenario (Encryption Technologies): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 1.4), an analyst evaluates the following technical requirement: 'chip on the motherboard that measures boot process' = TPM.' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: 'chip on the motherboard that measures boot process' = TPM...
- D)** Allow shared access among administrators with generic credentials

8. Corporate scenario (Encryption Technologies): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 1.4), an analyst evaluates the following technical requirement: 'dedicated appliance for cryptographic key operations' = HSM. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: 'dedicated appliance for cryptographic key operations' = HSM.
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

9. Corporate scenario (Encryption Technologies): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 1.4), an analyst evaluates the following technical requirement: 'Typical scenario: 'company issues encryption keys for the database and needs physical hardware protection' → HSM.'

What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: Typical scenario: 'company issues encryption keys for the database and ...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

10. Corporate scenario (Encryption Technologies): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 1.4), an analyst evaluates the following technical requirement: 'TPM = Trusted Platform Module — physical chip; measures boot + stores key'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: TPM = Trusted Platform Module — physical chip; measures boot + stores key...
- D)** Allow shared access among administrators using generic credentials

COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

1) B — Something you know, something you have, something you are.

✓ **Why it's correct:** Multi-factor authentication (MFA) requires combining at least two factors from distinct categories. The three classic categories are: something you know (knowledge, such as a password or PIN), something you have (possession, such as a physical token or code-generating app), and something you are (inherence, such as a fingerprint or facial recognition). The option 'Something you know, something you have, something you are' is the only one that correctly lists these three categories, as defined by NIST SP 800-63 and CompTIA Security+ SY0-701. MFA is an access control that mitigates credential compromise risks, as an attacker would need to overcome multiple independent barriers.

✗ **Why the others are wrong:**

- *Password, PIN, and secret answer:* Password, PIN, and secret answer are all examples of 'something you know' (knowledge factor). Although they are authentication mechanisms, they belong to the same category, so they do not constitute true MFA. Using multiple secrets of the same type is called multi-step authentication or apparent multifactor, but it does not meet the requirement of distinct categories. Additionally, secret answers are often vulnerable to social engineering attacks and can be discovered, not offering the same level of security as a second factor from a different category.
- *3 different passwords:* Three different passwords are still only a knowledge factor. Repeating passwords does not add a new authentication category; it only increases complexity within the same category. This is not MFA, because an attacker who compromises the password capture mechanism (e.g., keylogger or phishing) can obtain all three. Security is not multiplied by the number of passwords, but by the diversity of factors. CompTIA Security+ emphasizes that MFA requires factors of different types, not multiple instances of the same type.
- *Username, password, and email:* Username and email are identifiers, not authentication factors. The username and email address are public or easily discovered and do not prove identity. The password is a knowledge factor, but the other two are not authentication factors. Therefore, this combination does not represent MFA. Additionally, email can be used as a channel for sending codes, but by itself it is not a factor; it is a transport medium. The formal definition of MFA requires each factor to be from a different category (knowledge, possession, inherence), and here there is only one real factor.

2) B — CA (Certificate Authority).

✓ **Why it's correct:** The **CA (Certificate Authority)** is the central component of a PKI responsible for issuing, validating, and revoking digital certificates. It digitally signs certificates, ensuring the authenticity and integrity of public keys. Additionally, the CA maintains and publishes the CRL (Certificate Revocation List) and/or provides the OCSP (Online Certificate Status Protocol) service so that third parties can verify whether a certificate is still valid. In the CompTIA Security+ (SY0-701) syllabus, the CA is described as the trusted entity that validates identities and manages the certificate lifecycle, including revocation. Therefore, the CA is the exact answer for 'validating and revoking digital certificates'.

✗ **Why the others are wrong:**

- *RA (Registration Authority):* The RA (Registration Authority) is an entity subordinate to the CA that acts as an intermediary in the user registration process. Its main function is to verify the identity of the requester before forwarding the certificate request to the CA, but it does not issue, validate, or revoke certificates. The RA may assist in collecting documentation and initial authentication, but the final decision to issue and revoke is always the CA's. In the context of the question, the RA

does not perform certificate validation and revocation; it only facilitates registration, so it is incorrect.

- **CRL (Certificate Revocation List):** The CRL is a list periodically published by the CA containing the serial numbers of certificates that have been revoked before their expiration date. It is a lookup mechanism to check whether a certificate is revoked, but it does not perform validation or revocation itself. The CRL is an artifact generated by the CA; it does not make decisions or execute revocation actions. Furthermore, validating a certificate involves verifying the CA's signature, the chain of trust, and temporal validity, which is not done by the CRL. Therefore, CRL is only a lookup tool, not the component responsible for validation and revocation.
- **OCSP (Online Certificate Status Protocol):** OCSP is a real-time query protocol that allows checking whether a specific certificate has been revoked by querying the CA or an OCSP responder directly. It offers a faster alternative to the CRL, but it is not the component that validates or revokes certificates; it is only a status-checking service. The responsibility for issuing, validating, and revoking certificates remains with the CA. OCSP depends on the CA to obtain revocation information. Thus, it is not the correct answer for the function of validating and revoking certificates.

3) A — KMS (Key Management Service).

✓ **Why it is correct:** KMS (Key Management Service) is a managed encryption service offered by cloud providers (AWS KMS, Azure Key Vault, Google Cloud KMS) that centralizes the complete lifecycle of cryptographic keys: generation, secure storage, automatic rotation, granular access policies via IAM, and usage auditing. In the context of CompTIA Security+ (domain 3.4 - 'Given a scenario, apply cybersecurity solutions to the cloud'), KMS is the standard solution for managing encryption keys in cloud environments, enabling data at rest (EBS, S3, RDS) and in transit to be protected with customer-managed or provider-managed keys. It exactly meets the requirement to 'create, rotate, and control access' to keys, making it the correct answer.

✗ **Why the others are wrong:**

- **IAM:** IAM (Identity and Access Management) is a service for managing identities and permissions that controls who can access which cloud resources, defining users, groups, roles, and policies. Although IAM is used to authorize access to KMS, it does not manage cryptographic keys itself — it does not create, rotate, or store keys. Therefore, it is incorrect for the question, which specifically asks for the key management service.
- **CDN:** CDN (Content Delivery Network) is a distributed network of edge servers that caches static content (images, videos, scripts) to reduce latency and improve delivery to users. It has no relation to cryptographic key management; its function is performance optimization and availability, not key security. Thus, it does not meet the requirement.
- **VPC:** VPC (Virtual Private Cloud) is an isolated virtual network within the cloud, where the user defines subnets, route tables, gateways, and security groups. It is a network infrastructure service, not a key management service. Although it can host instances that use KMS, the VPC itself does not create, rotate, or control cryptographic keys. Therefore, it is incorrect for the question.

4) A — Implement the corresponding solution: TPM = Trusted Platform Module — physical chip; measures boot + stores key....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 1.4 (Encryption Technologies): TPM = Trusted Platform Module — physical chip; measures boot + stores key. The TPM is a hardware-based root of trust that stores cryptographic keys and performs integrity measurements during boot, enabling secure boot and attestation.

✗ **Why the others are wrong:**

- **Temporarily disable audit logs to accelerate system throughput:** Directly violates the Accounting

pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).

- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user behavior, and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

5) B — Implement the corresponding solution: HSM = Hardware Security Module — dedicated for high-value keys....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 1.4 (Encryption Technologies): HSM = Hardware Security Module — dedicated for high-value keys. An HSM is a physical device that safeguards and manages digital keys, performs encryption/decryption, and provides tamper-resistant key storage for high-value keys.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

6) A — Implement the corresponding solution: Secure Enclave: segregated processor (Apple) for biometrics/payment..

✓ **Why it is correct:** Per the official CompTIA Security+ (SY0-701) exam objectives for lesson 1.4 (Encryption Technologies): Secure Enclave: segregated processor (Apple) for biometrics/payment. The Secure Enclave is a dedicated, isolated coprocessor built into Apple SoCs that handles sensitive operations such as biometric data processing (Touch ID/Face ID), cryptographic key management, and payment tokenization. It provides hardware-based isolation so that even if the main OS is compromised, the enclave's secrets remain protected.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaches compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

7) C — Implement the corresponding solution: 'chip on the motherboard that measures boot process' = TPM....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 1.4 (Encryption Technologies): 'chip on the motherboard that measures boot process' =

TPM.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators with generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

8) B — Implement the corresponding solution: 'dedicated appliance for cryptographic key operations' = HSM..

✓ **Why it is correct:** Per the official CompTIA Security+ (SY0-701) exam objectives for lesson 1.4 (Encryption Technologies): 'dedicated appliance for cryptographic key operations' = HSM. An HSM (Hardware Security Module) is a dedicated, tamper-resistant hardware appliance that generates, stores, and manages cryptographic keys and performs cryptographic operations (encryption, decryption, signing, key exchange) in a hardened environment. HSMs are used for PKI, database encryption, TLS offloading, and code signing, and they provide strong key protection and FIPS 140-2/3 validation.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaches compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials*: Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

9) B — Implement the corresponding solution: Typical scenario: 'company issues encryption keys for the database and

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 1.4 (Encryption Technologies): Typical scenario: 'company issues encryption keys for the database and needs physical hardware protection' → HSM.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who made critical changes or malicious commands.

10) C — Implement the corresponding solution: TPM = Trusted Platform Module — physical chip; measures boot + stores key....

✅ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 1.4 (Encryption Technologies): TPM = Trusted Platform Module — physical chip; measures boot + stores key. A TPM is a hardware-based security component that provides secure storage of cryptographic keys and performs platform integrity measurements during boot, enabling features like full disk encryption and secure boot.

❌ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* This directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* This destroys individual accountability and non-repudiation. It makes it impossible to prove who made critical changes or executed malicious commands.